

Vulnerability assessment of publicly accessible database infrastructure

1. Scenario

Conducted a vulnerability assessment for an e-commerce organization that stored customer, marketing, and analytics data on a publicly accessible MySQL database server. The assessment focused on identifying security risk associates with exposed access control and evaluating the potential impact on business opera.

2. Objective

Assess the security posture of a database environment exposed to the public internet, identify threats to confidentiality, integrity, and availability (CIA triad) and develop a remediation strategy aligned with cybersecurity risk management principles.

3. Activities performed

- reviewed system architecture, server configuration, and database environment
- Evaluated access control weakness affecting a publicly accessible database server.
- Defined the scope of the vulnerability, assessment using NIST risk assessment methodology.
- Identified potential threat actors and attack scenarios.
- Assessed likelihood, severity, and overall risk level.
- Analyzed business impact associated with unauthorized access and data exposure.
- Developed a remediation strategy to reduce attack surface and improve system security.

4. Key findings

- the database server was accessible from the public internet.
- Sensitive customer and business data could be exposed through unauthorized access.
- Open access significantly increased the likelihood of external attacks
- Existing security measures were not sufficient to mitigate exposure risks.

5. Risk assessment

Threat source	Threat event	Risk level;
External hacker	Data exfiltration of sensitive information	High
Employee	Disruption of mission-critical operations	Medium
Customer/User	Modification or deletion of critical data	Low

6. Remediation Recommendations

- implement role-based access control (RBAC)
- Enforce strong authentication mechanisms
- Enable multi-factor authentication (MFA)
- Restrict database access through IP allow-listening
- Replace legacy SSL configurations with modern TLS encryption
- Implement auditing and monitoring of database access activity.
- Reduce exposure by limiting public access to authorized users only.

7. Frameworks and standards

- NIST SP 800-30 Rev.1
- Vulnerability assessment methodology
- Risk analysis
- Access control
- Authentication and authorization
- Database security
- Security remediation planning

8. Skills demonstrated

- vulnerability assessment
- Risk analysis
- Threat modeling
- Security documentation
- Security control evaluation
- Remediation planning
- Database security fundamentals
- NIST Risk Assessment Methodology